

Week 1 Theory-Based Assignment:

GRC Frameworks and Principles

Student Name: _____ Imelda Sanya _____

Reg. No: _____ C11/26/CGRCE/17576 _____

Date: _____ 12/07/2026 _____

Lab Objectives:

This lab assignment is designed to help you:

- Understand the fundamental concepts of Governance, Risk, and Compliance (GRC)
- Identify and compare different GRC frameworks
- Apply GRC principles to real-world scenarios
- Develop critical thinking skills in evaluating GRC implementation

Instructions:

Complete all parts of this lab assignment. Please submit your completed document to your instructor by the specified due date. All answers should be typed directly into this document and submitted as a **PDF**

Part 1: GRC Concepts (25 points)

1. Define Governance, Risk, and Compliance in your own words. Explain how these three components are interconnected. (5 points)

Answer: Governance refers to the policies and procedures that define how an organization operates

Risk is the likelihood of a vulnerability being exploited

Compliance refers to adhering to the policies and procedure that have been defined by an organization both internally and externally

2. Explain the importance of GRC in modern organizations. Provide at least three specific benefits that effective GRC implementation can bring to an organization. (5 points)

Answer:

GRC enables an organization to be compliant and address and manage risks earlier to ensure they meet regulatory requirements_.

Benefits of GRC:

1. Identifies, assesses and mitigates organizational risks
2. Ensure organization is compliant with laws, regulations and standards
3. Aligns IT with business objectives while managing risks

3. Identify and describe three key challenges organizations face when implementing GRC programs. (5 points)

Answer:

1. Siloed operations: Different departments working independently making it difficult to share information and coordinate efforts
2. Lack of executive support: Without support from the senior leadership, GRC may lack sufficient funding, resources and strategic direction
3. Resistance to change: Employees being reluctant to adopt the GRC policies and procedures due to fear of increased work or lack of understanding

4. Describe the role of the Board of Directors, executive management, and operational staff in GRC implementation. (5 points)

Answer:

Board of directors sets direction and provides oversight
 Executive management implements strategy and manages the GRC program
 Operational staff executes the policies and manages risks

5. Explain how technology can support GRC initiatives. Provide specific examples of GRC tools or technologies and their benefits. (5 points)

Answer:

GRC supports the GRC initiatives by automating processes, improving visibility into risks, ensuring regulatory compliance, and providing real-time reporting for better decision making

Examples of GRC Tools

1. Security Information and Event Management like Splunk that continuously monitor and analyze security events to detect threats and compliance violations. This enables real-time risk detection, faster incident response, and supports compliance reporting.
2. ServiceNow GRC – Automates risk assessments, compliance tracking, policy management, and incident response. This ensures workflows are streamlined, reduces manual effort, and enhances collaboration across departments.

Part 2: GRC Frameworks Comparison (25 points)

Complete the following table comparing three major GRC frameworks. Research each framework and fill in the required information.

Framework Aspect	COSO Framework	NIST Cybersecurity Framework	ISO 31000
Primary Focus	focuses on enterprise governance, internal controls, and overall	focuses specifically on cybersecurity risk management.	focuses on general risk management principles applicable to any organization.

	risk management.		
Key Components	Control environment, risk assessment, control activities	Govern, identify, protect, detect, respond, recover	Principles, framework, and risk management process
Benefits	Improves organizational governance, strengthens internal controls, enhances risk management, supports regulatory compliance, and helps prevent fraud.	Improves cybersecurity resilience, provides a structured approach to managing cyber risks, enhances threat detection and response, and improves communication of cybersecurity risks.	Provides a consistent approach to managing risks, supports better decision-making, improves organizational resilience, and can be applied across different industries and risk types.
Limitations	Broad and flexible but can be complex and requires customization.	Strong for cybersecurity but does not cover all business risks.	Provides guidance but lacks detailed implementation steps and controls.

Part 3: Case Study Analysis (30 points)

Case Study: HealthTech Solutions

HealthTech Solutions is a mid-sized healthcare technology company that develops software for hospitals and clinics. The company has experienced rapid growth over the past three years, expanding from 50 to 200 employees. They handle sensitive patient data through their applications and are subject to HIPAA regulations.

Recently, HealthTech experienced a minor data breach where some patient records were temporarily exposed due to a configuration error. While the issue was quickly resolved and affected only a small number of records, the incident raised concerns about the company's governance and compliance practices.

The CEO has recognized that the company's informal approach to governance and compliance is no longer sufficient given their growth and the sensitive nature of their business. The company currently has:

- No formal risk assessment process
- Limited documentation of policies and procedures
- Inconsistent security controls across different products
- No dedicated compliance officer or team
- Ad-hoc approach to regulatory compliance

The CEO wants to implement a formal GRC program to address these issues and ensure the company can continue to grow while maintaining compliance with regulations and protecting sensitive data.

1. Identify the key GRC challenges facing HealthTech Solutions. (5 points)

Answer:

They have limited documentation of policies and procedures

Inconsistent security controls across products
Insufficient governance structure and accountability
Lack of formal risk assessment process
Reactive approach to regulatory compliance

2. Recommend a specific GRC framework that would be most appropriate for HealthTech Solutions. Justify your choice. (5 points)

Answer:

NIST CSF is the most suitable choice because HealthTech's primary challenge is protecting sensitive patient information and strengthening cybersecurity governance. It provides a practical, flexible, and risk-based approach to improve security, compliance, and organizational resilience.

3. Outline a step-by-step implementation plan for establishing a GRC program at HealthTech Solutions. (10 points)

Answer:

1. Obtain Executive Support and Define GRC Objectives

- The senior leadership should sponsor the GRC initiative and define clear objectives.
- Establish goals such as improving HIPAA compliance, protecting patient data, reducing cybersecurity risks, and strengthening governance.

2. Establish a GRC Governance Structure

- Create a GRC committee with representatives from executive management, IT, security, legal, compliance, and business teams.
- Assign clear roles and responsibilities, including appointing a compliance officer or GRC manager.

3. Perform an Initial Risk Assessment to identify current risks, vulnerabilities, and compliance gaps, including issues that contributed to the recent data breach.

4. Implement a suitable framework such as the NIST Cybersecurity Framework (CSF).

5. Develop and Document Policies and Procedures e.g. Data protection and privacy, Data access control, Incident response, Secure software development, Risk management, Employee security awareness

6. Define baseline security requirements for all HealthTech applications.

7. Deploy GRC tools to automate risk tracking, compliance management, policy management, and reporting.

8. Establish Compliance Management Processes

9. Provide Training and Promote Security Awareness

10. Monitor, Measure, and Continuously Improve the GRC Program

4. Describe three specific metrics or key performance indicators (KPIs) that HealthTech Solutions could use to measure the effectiveness of their GRC program. (5 points)

Answer:

1. Number of Security Incidents and Data Breaches
2. Compliance Audit Findings and Remediation Rate
3. Risk Assessment and Mitigation Progress

5. Explain how implementing a formal GRC program could help prevent similar data breaches in the future. (5 points)

Answer:

1. Better Compliance Monitoring and Accountability
2. Regular audits and compliance monitoring would help ensure HIPAA requirements are continuously met and issues are identified early.
3. A GRC program would provide employees with regular training on security policies, data protection, and compliance responsibilities, reducing human errors that could expose sensitive patient information
4. Establish regular risk assessments to identify vulnerabilities, such as incorrect system configurations, before they lead to security incidents. Risks can be documented, prioritized, and assigned to responsible owners for remediation
5. Help HealthTech create and enforce consistent security policies and controls across all products and systems. This reduces security gaps caused by inconsistent configurations and ensures applications follow approved security standards.

Part 4: Reflection (20 points)

1. Based on what you've learned about GRC frameworks and principles, how would you explain the importance of GRC to a non-technical executive? (5 points)

Answer:

1. GRC provides leaders with clear information about risks and compliance, enabling informed business decisions.
2. It helps identify and manage risks before they become costly problems, such as data breaches, financial losses, or operational disruptions
3. Helps the organization comply with laws and regulations (such as HIPAA), reducing the risk of fines, legal action, and reputational damage.
4. Strong governance and security practices build trust with customers, partners, and investors by demonstrating that the organization protects sensitive information.
5. As the organization grows, GRC provides structured processes, clear accountability, and consistent controls that enable the business to expand while maintaining security and compliance.

2. Discuss how GRC principles apply to your current or future career in cybersecurity. Provide specific examples. (5 points)

Answer:

In my current role as a Software Engineer in Test, I can apply GRC by verifying that applications meet security and compliance requirements during testing. For example, when testing automated certificate renewal workflows, I can validate access controls, encryption, audit logging, and regulatory compliance to ensure secure and reliable software before deployment.

Cybersecurity requires ongoing monitoring of threats, vulnerabilities, and compliance status. For example, I would use security monitoring tools such as SIEM solutions to detect suspicious activity, respond to incidents quickly, and recommend improvements based on audit findings.

3. What do you think are the most significant emerging trends or challenges in the GRC field? How might these impact organizations in the next 5 years? (5 points)

Answer:

As organizations increasingly adopt AI, they will need governance frameworks to ensure AI systems are ethical, transparent, secure, and compliant with evolving regulations. Organizations that fail to govern AI effectively may face legal, operational, and reputational risks.

Organizations are increasingly adopting automated GRC platforms to manage risks, monitor compliance, and generate real-time reports. Automation will improve efficiency, reduce manual errors, and enable faster decision-making, but it will also require skilled professionals to manage and oversee these technologies.

4. What aspects of GRC do you find most interesting or challenging? Why? (5 points)

Answer:

I am interested in integrating security into software development and testing. As a Software Engineer in Test with an interest in cybersecurity, I find it rewarding to ensure that applications are not only functional but also secure and compliant. For example, security testing, certificate lifecycle management, and validating access controls help reduce vulnerabilities before software is released.

The most challenging aspect of GRC is keeping up with constantly evolving regulations and cybersecurity threats. Organizations must continuously adapt to new laws, emerging technologies such as AI, and increasingly sophisticated cyberattacks. This requires ongoing learning, regular risk assessments, and continuous improvement of security controls.